
Informe Profesional de Pentesting

Actividad A08, Hacking Ético

Cliente: INSECUR S.A.
Laboratorio: TryHackMe

Seguridad Aplicada a Sistemas de Información
Licenciatura en Sistemas de Información, Facultad de Informática y Diseño
Docente: Ing. Rodrigo Atilio Elgueta
Ciclo Académico Vigente

Juan Narváez

06 de octubre de 2026

Contents

1	Datos generales	2
2	Pre-pentesting	2
3	Durante: Hallazgos por fase	3
3.1	Resumen ejecutivo de hallazgos	9
4	Post-pentesting: Recomendaciones	10
5	Protocolo de Contingencia	10
6	Anexos	11

1. Datos generales

Campo	Valor
Cliente	INSECUR S.A.
Contratista (alumno)	Juan Narváez
DNI	44.993.734
Username TryHackMe	narvaezjuan
Email institucional	narvaezjuan@uch.edu.ar
Sala de elección (Nivel 2)	Vulniversity
Branch en GitHub	narvaez-juan
Fecha de inicio	06/10/2026
Fecha de cierre	06/10/2026

2. Pre-pentesting

Alcance del trabajo

El alcance autorizado comprende exclusivamente los entornos de laboratorio sandbox provistos por la plataforma TryHackMe, correspondientes a las siguientes tres salas:

- **Pentesting Fundamentals** (núcleo obligatorio, sala teórica): metodología y fases del pentesting profesional.
- **Basic Pentesting** (núcleo obligatorio, sala práctica): máquina Linux con servicios SSH, SMB, Apache y Tomcat.
- **Vulniversity** (sala de elección, Nivel 2): máquina Linux con servicios FTP, SSH, SMB, Squid Proxy y un servidor web en puerto no estándar.

Quedan excluidos de este alcance todos los sistemas de producción de INSECUR S.A. y cualquier sistema ajeno a las máquinas de laboratorio asignadas por TryHackMe. No se realizó ninguna acción sobre sistemas reales.

Reglas de Enfrentamiento (ROE)

- El trabajo se realizó exclusivamente a través de la VPN oficial de TryHackMe (OpenVPN), contra las IPs asignadas dinámicamente por la plataforma para cada máquina.
- No se utilizaron técnicas de denegación de servicio (DoS) ni ataques que pudieran degradar la disponibilidad de la infraestructura de TryHackMe.
- Los ataques de fuerza bruta (Hydra) se limitaron a los servicios SSH de las máquinas de laboratorio, con throttling por defecto de la herramienta.
- Toda credencial, clave privada y flag obtenida se trató como información sensible: las flags se documentan únicamente mediante su hash SHA-256 (Sección 6).

- Ante cualquier incidente (por ejemplo, la expiración o caída de una máquina de laboratorio), se documentó el evento y se reinició la máquina desde la plataforma, sin intentar accesos no autorizados a infraestructura ajena.

Autorización

Declaro que cuento con autorización expresa de la cátedra de Seguridad Aplicada a Sistemas de Información (FID-UCH) para trabajar sobre los entornos de TryHackMe indicados en esta guía, en el marco de la Actividad A08. Todas las acciones documentadas en este informe se realizaron dentro de dicho alcance autorizado.

Metodología utilizada

Se siguió un flujo de trabajo basado en las fases estándar de un pentest profesional, consistente con los marcos **PTES** (Penetration Testing Execution Standard), **OSSTMM** y **OWASP Testing Guide**, estudiados en la sala *Pentesting Fundamentals*:

1. **Reconocimiento (Information Gathering):** identificación de hosts, puertos y servicios mediante ping y nmap.
2. **Escaneo y enumeración:** determinación de versiones de servicios (`nmap -sC -sV`), enumeración de recursos compartidos SMB (`smbclient`), descubrimiento de directorios web (`gobuster`) y descarga de archivos expuestos (`curl`).
3. **Explotación:** ataque de diccionario contra SSH (`hydra`), obtención y crackeo de claves privadas (`ssh2john + john`), y subida de un shell reverse PHP camuflado como `.phtml` para evadir el filtro de extensiones de un formulario de carga de archivos.
4. **Post-explotación / escalada de privilegios:** identificación de binarios SUID (`find -perm -4000`) y abuso del bit SUID sobre `systemctl` para crear un servicio que leyera la flag de root.
5. **Reporte:** documentación de hallazgos, evidencia y recomendaciones, conforme a esta plantilla.

El tipo de prueba aplicado fue de **caja negra** (*black box*): no se contó con información previa sobre la configuración interna, el código fuente ni las credenciales de las máquinas objetivo; todo el conocimiento se construyó mediante enumeración activa.

3. Durante: Hallazgos por fase

H-01: Recurso compartido SMB accesible de forma anónima (Basic Pentesting)

Campo	Valor
ID del hallazgo	H-01
Fase	Enumeración

Descripción	El servicio Samba (smbd 4.6.2, puertos 139/445) expone un recurso compartido llamado Anonymous accesible sin autenticación (smbclient -L <IP> -N). Dentro de dicho recurso se encontró el archivo staff.txt , que revela nombres de usuarios internos (Jan, Kay).		
Componente afectado	Servicio Samba smbd 4.6.2, recurso Anonymous		
Categoría (OWASP / CWE)	CWE-284 (Improper Access Control)		
CVE (si aplica)	No aplica (error de configuración, no de versión)		
CVSS estimado	☒ Medio		
Evidencia (captura / comando)	smbclient -L \$IP -N y descarga de staff.txt , registrados en bitacora/basicpentesting/04_smbclient_list.txt y 09_staff.txt .		
Herramienta utilizada	smbclient		
Impacto en la Tríada CIA	☒ Confidencialidad		
Salvaguarda propuesta	Deshabilitar el acceso anónimo (guest ok = no) en smb.conf , restringir los recursos compartidos a usuarios autenticados y auditar periódicamente los shares expuestos.		
Riesgo residual tras aplicar	☒ Bajo		

H-02: Divulgación de información sensible en directorio web (Basic Pentesting)

Campo	Valor
ID del hallazgo	H-02
Fase	Escaneo

Descripción	Mediante <code>gobuster</code> se descubrió el directorio <code>/development/</code> en el servidor Apache (puerto 80), accesible sin restricción, conteniendo los archivos <code>dev.txt</code> y <code>j.txt</code> . Estos archivos contienen una conversación interna entre los desarrolladores Kay y Jan, donde Kay informa haber auditado <code>/etc/shadow</code> y crackeado fácilmente la contraseña de Jan, confirmando el uso de una contraseña débil.
Componente afectado	Apache httpd 2.4.41, directorio <code>/development/</code>
Categoría (OWASP / CWE)	A01:2021 – Broken Access Control / CWE-200 (Information Exposure)
CVE (si aplica)	No aplica
CVSS estimado	☒ Medio
Evidencia (captura / comando)	<code>gobuster dir -u http://\$IP -w ...</code> , descarga con <code>curl</code> , registrados en <code>bitacora/basicpentesting/05_gobuster_80.txt</code> , <code>07_dev.txt</code> , <code>08_j.txt</code> .
Herramienta utilizada	<code>gobuster</code> , <code>curl</code>
Impacto en la Tríada CIA	☒ Confidencialidad
Salvaguarda propuesta	Eliminar directorios y archivos de desarrollo del entorno de producción; aplicar control de acceso y revisión de despliegues antes de publicar contenido web.
Riesgo residual tras aplicar	☒ Bajo

H-03: Contraseña SSH débil, crackeada por diccionario (Basic Pentesting)

Campo	Valor
ID del hallazgo	H-03
Fase	Explotación

Descripción	Con los usuarios obtenidos en H-01 y H-02, se ejecutó un ataque de diccionario con Hydra contra el servicio SSH (OpenSSH 8.2p1) utilizando la wordlist <code>rockyou.txt</code> . La contraseña del usuario <code>jan</code> fue encontrada en la lista, permitiendo acceso remoto autenticado al sistema.	
Componente afectado	Servicio SSH, cuenta <code>jan</code>	
Categoría (OWASP / CWE)	CWE-521 (Weak Password Requirements)	
CVE (si aplica)	No aplica	
CVSS estimado	☒ Alto	
Evidencia (captura / comando)	<code>hydra -l jan -P rockyou.txt ssh://\$IP;</code>	acceso confirmado con <code>ssh jan@\$IP</code> .
Herramienta utilizada	Hydra, SSH	
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad	
Salvaguarda propuesta	Implementar política de contraseñas robustas (longitud mínima, complejidad), autenticación por clave pública en lugar de contraseña, y bloqueo tras intentos fallidos (<code>fail2ban</code>).	
Riesgo residual tras aplicar	☒ Bajo	

H-04: Clave privada SSH con permisos de lectura global y passphrase débil (Basic Pentesting)

Campo	Valor
ID del hallazgo	H-04
Fase	Post-explotación

Descripción	Una vez autenticado como <code>jan</code> , se detectó que la clave privada SSH del usuario <code>kay</code> (<code>/home/kay/.ssh/id_rsa</code>) tenía permisos de lectura para todos los usuarios del sistema (<code>-rw-r--r--</code>). La clave fue copiada y su passphrase crackeada instantáneamente con John the Ripper y la wordlist <code>rockyou.txt</code> , permitiendo el acceso como <code>kay</code> . Desde esa cuenta se accedió al archivo <code>pass.bak</code> , que contenía una contraseña de texto plano.
Componente afectado	Clave privada de <code>kay</code> , archivo <code>pass.bak</code>
Categoría (OWASP / CWE)	CWE-522 (Insufficiently Protected Credentials) / CWE-732 (Incorrect Permission Assignment)
CVE (si aplica)	No aplica
CVSS estimado	☒ Alto
Evidencia (captura / comando)	<code>ssh2john.py</code> + <code>john --wordlist=rockyou.txt</code> , registrados en <code>bitacora/basicpentesting/kay_hash.txt</code> .
Herramienta utilizada	<code>ssh2john</code> , John the Ripper (jumbo)
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad
Salvaguarda propuesta	Restringir permisos de archivos de claves privadas a 600 (solo el propietario), exigir passphrases robustas y eliminar archivos de credenciales en texto plano (<code>pass.bak</code>) del sistema.
Riesgo residual tras aplicar	☒ Bajo

H-05: Carga de archivos sin validación efectiva de extensión (Vulnversity)

Campo	Valor
ID del hallazgo	H-05
Fase	Explotación

Descripción	El servidor web (Apache 2.4.41, puerto 3333) expone en <code>/internal/</code> un formulario de carga de archivos que bloquea la extensión <code>.php</code> pero no filtra extensiones equivalentes como <code>.phtml</code> . Se subió un shell reverso PHP renombrado a <code>.phtml</code> , que al ser invocado otorgó ejecución remota de comandos como el usuario <code>www-data</code> .
Componente afectado	Formulario de carga <code>/internal/</code> , Apache 2.4.41
Categoría (OWASP / CWE)	A04:2021 – Insecure Design / CWE-434 (Unrestricted Upload of File with Dangerous Type)
CVE (si aplica)	No aplica (falla de configuración de la aplicación)
CVSS estimado	☒ Crítico
Evidencia (captura / comando)	Subida vía formulario web + ejecución en <code>/internal/uploads/php-reverse-shell.phtml</code> ; conexión recibida con <code>nc -lvnp 1234</code> ; <code>whoami</code> devolvió <code>www-data</code> ; flag de usuario obtenida en <code>/home/bill/user.txt</code> .
Herramienta utilizada	Shell reverso PHP (pentestmonkey), Netcat, Gobuster
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad
Salvaguarda propuesta	Validar el tipo de archivo por contenido (<i>magic bytes</i>) y no solo por extensión, usar listas blancas estrictas, almacenar los archivos subidos fuera del <i>document root</i> y deshabilitar la ejecución de scripts en el directorio de uploads.
Riesgo residual tras aplicar	☒ Bajo

H-06: Escalada de privilegios mediante binario SUID `systemctl` (Vulniversity)

Campo	Valor
ID del hallazgo	H-06
Fase	Post-explotación

Descripción	Al enumerar binarios con el bit SUID activo (<code>find / -perm -4000 -type f</code>) desde la shell obtenida en H-05, se identificó que <code>/bin/systemctl</code> tenía el bit SUID habilitado, algo inusual para ese binario. Esto permitió crear y habilitar un servicio <code>systemd</code> malicioso que se ejecuta con privilegios de <code>root</code> , utilizado para leer la flag <code>/root/root.txt</code> .		
Componente afectado	<code>/bin/systemctl</code>		
Categoría (OWASP / CWE)	CWE-250 (Execution with Unnecessary Privileges)		
CVE (si aplica)	No aplica (error de configuración de permisos)		
CVSS estimado	☒ Crítico		
Evidencia (captura / comando)	<code>find / -perm -4000 -type f;</code> creación de unidad <code>systemd</code> con <code>systemctl link</code> y <code>systemctl enable --now;</code> flag de root obtenida en <code>/tmp/root</code> .		
Herramienta utilizada	systemctl, shell Bash		
Impacto en la Tríada CIA	☒ Confidencialidad ☒ Integridad ☒ Disponibilidad		
Salvaguarda propuesta	Eliminar el bit SUID de binarios que no lo requieren (<code>chmod u-s /bin/systemctl</code>), aplicar el principio de mínimo privilegio y auditar periódicamente binarios SUID/SGID con herramientas como LinPEAS.		
Riesgo residual tras aplicar	☒ Bajo		

3.1. Resumen ejecutivo de hallazgos

Severidad	Cantidad	ID de hallazgos
Crítico	2	H-05, H-06
Alto	2	H-03, H-04
Medio	2	H-01, H-02
Bajo	0	:
Total	6	

4. Post-pentesting: Recomendaciones

Recomendaciones técnicas (parches y configuraciones)

1. **(Crítico)** Validar archivos subidos por contenido real (*magic bytes*) y lista blanca de extensiones, deshabilitando la ejecución de scripts en directorios de carga (H-05).
2. **(Crítico)** Retirar el bit SUID de `systemctl` y auditar todos los binarios SUID/SGID del sistema (H-06).
3. **(Alto)** Forzar política de contraseñas robustas y migrar la autenticación SSH a claves públicas, deshabilitando el login por contraseña (H-03).
4. **(Alto)** Corregir permisos de claves privadas a 600 y eliminar archivos de credenciales en texto plano del sistema de archivos (H-04).
5. **(Medio)** Deshabilitar el acceso anónimo a recursos SMB y exigir autenticación (H-01).
6. **(Medio)** Eliminar directorios y archivos de desarrollo/debug de los entornos expuestos públicamente (H-02).

Recomendaciones administrativas (políticas y procesos)

- Capacitar al personal de desarrollo sobre manejo seguro de credenciales y prohibir su circulación por canales no cifrados (correo, notas internas, archivos de texto).
- Establecer un proceso de revisión de seguridad previo a cada despliegue (*code review* + *checklist* de hardening).
- Implementar auditorías periódicas de configuración (SMB, SSH, permisos de archivos, binarios SUID) con herramientas automatizadas.
- Definir una política formal de gestión de contraseñas y rotación de credenciales.
- Incorporar un programa de pentesting recurrente (al menos semestral) sobre los sistemas críticos de la organización.

5. Protocolo de Contingencia

Escenario de falla

Durante la fase de explotación (H-05), la carga y ejecución de un shell reverso sobre un servicio web de producción podría, en un escenario real, generar inestabilidad en el proceso de Apache o consumir recursos del servidor de forma inesperada. De forma análoga, la creación de una unidad `systemd` maliciosa (H-06) podría interferir con servicios legítimos del sistema si no se revierte correctamente tras la prueba.

Impacto sobre la continuidad del negocio

Si estos vectores fueran explotados sobre un sistema productivo de INSECUR S.A., los procesos de atención web (consultas de clientes, servicios internos expuestos) se verían interrumpidos durante el tiempo que tome detectar el compromiso, revertir los cambios maliciosos y restaurar el servicio desde una copia de seguridad íntegra. Se estima un impacto de interrupción total del servicio web mientras dure la contención.

Plan de respuesta

1. **Activación:** la falla se detecta mediante monitoreo de servicios (caída de Apache, procesos desconocidos, alertas de un EDR/IDS) o reportes de usuarios sobre indisponibilidad.
2. **Contención:** en los primeros 15 minutos se aísla el host afectado de la red (segmentación o apagado de interfaz), se revocan credenciales comprometidas y se detienen los servicios o unidades `systemd` no reconocidas.
3. **Recuperación:** se restaura el servicio desde la última copia de seguridad íntegra verificada, o se promueve un servidor espejo (failover) mientras se analiza el host comprometido en un entorno aislado (forense).
4. **Comunicación:** se notifica a dirección de IT y a la gerencia de INSECUR S.A. de forma inmediata; si hubo exposición de datos de clientes, se evalúa la notificación a las autoridades competentes según la normativa vigente.
5. **Post-mortem:** se documenta la cronología completa del incidente, causa raíz, acciones tomadas y lecciones aprendidas, actualizando el plan de contingencia y las medidas de hardening correspondientes.

RTO y RPO estimados

RTO (Recovery Time Objective): 2 horas, asumiendo disponibilidad de backups verificados y un servidor espejo preconfigurado.

RPO (Recovery Point Objective): 24 horas, en línea con una política de backups diarios.

6. Anexos

Anexo A: Bitácora de comandos

La bitácora completa de comandos ejecutados se encuentra en el branch `narvaez-juan`, organizada por sala:

- `bitacora/basicpentesting/`: reconocimiento, escaneo, enumeración SMB/web, credenciales y hashes de Basic Pentesting.
- `bitacora/vulniversity/`: escaneo nmap, gobuster y hashes de flags de Vulniversity.

Los archivos de bitácora fueron generados directamente con las opciones `-oN` de nmap y redirección de salida (`tee`), sin edición manual posterior más que la organización en carpetas.

Anexo B: Capturas de pantalla

Carpeta `evidencias/` con subcarpetas por fase (`reconocimiento/`, `escaneo/`, `explotacion/`, `post/`) y por sala (`evidencias/vulniversity/`). Las capturas incluyen el username de TryHackMe (`narvaezjuan`), la fecha y hora del sistema, y la IP de la máquina objetivo en cada caso, conforme al mecanismo de control de autenticidad de la guía.

Anexo C: Hashes de las flags obtenidas

```
1 # Formato: flag_id  sha256_hash
2 H-Vuln-User
   d324bd433001e5bdfe39e04d794539c15b51982a5bf6fc78efea46369b7bf956
3 H-Vuln-Root
   cfbc740435ad60030304080e35131ffcaf8ac5f71b65e002f5b546aa3cda7ce8
4 H-BP-Final      3
   ffd53ec80858f9ddcd75d69102724ab1bc1020855fff924227f618c4bfccf57
```

Hashes calculados con `echo -n "<flag>" | sha256sum` sobre el valor real de cada flag/credencial obtenida. Las flags en texto plano no se publican en este informe, conforme al mecanismo de control de autenticidad de la cátedra.

Anexo D: Declaración ética firmada

Declaro que todas las actividades descriptas en este informe se realizaron dentro del alcance autorizado, en los entornos controlados (sandbox) de TryHackMe asignados por la cátedra, y con fines exclusivamente académicos. No se aplicó ninguna de las técnicas aquí documentadas contra sistemas reales ni ajenos al laboratorio.

Juan Narváez

06/10/2026